

XSS 漏洞报告 (Lab1: 将 XSS 映射到 HTML 上下文中, 且没有编码)

1. 漏洞名称

跨站脚本攻击 (Cross-Site Scripting, XSS) — 反射型 XSS (Reflected XSS)

2. 漏洞等级

高危 (High)

3. 漏洞描述

该网站的搜索功能存在反射型 XSS 漏洞。后端服务器在接收到搜索关键词后, **未对用户输入进行任何 HTML 编码或过滤**, 直接将用户输入的内容拼接到了页面响应中。攻击者可以构造包含恶意 JavaScript 代码的 URL, 当受害者点击该链接时, 恶意代码会在受害者的浏览器中执行, 导致敏感信息泄露。

4. 漏洞位置

请求方式: GET /search

漏洞参数: search (URL 查询参数)

5. 漏洞复现过程

第一步: 发现搜索反射点

访问网站首页, 在搜索框中输入一段特定的测试字符串 (如 test123), 点击搜索, 发现搜索框的值和页面上“0 search results for "...”的提示中, 原样回显了该字符串。这证明搜索内容会被服务器直接反射回页面。

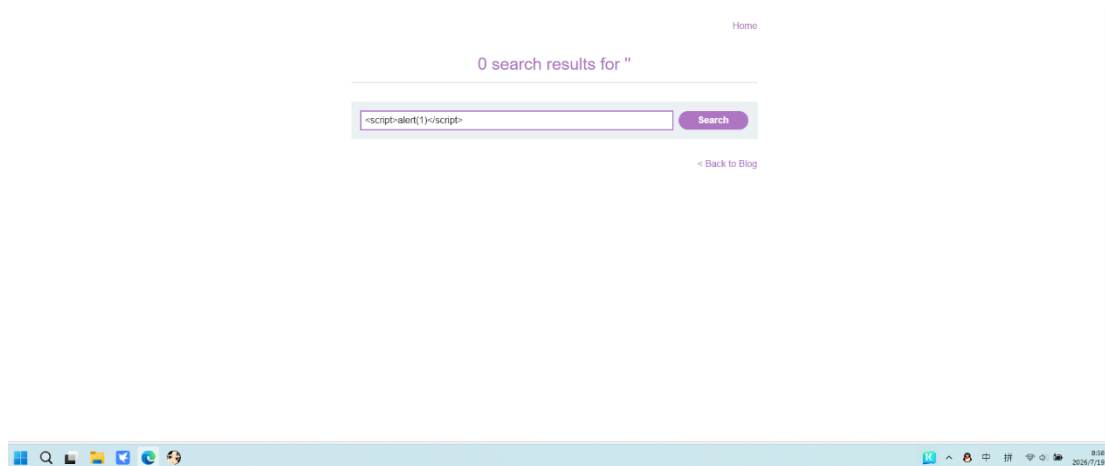
第二步: 构造 XSS PoC Payload

为了验证是否为 XSS 漏洞, 将搜索关键词替换为标准的 <script> 标签测试 Payload:

html

```
<script>alert(1)</script>
```

图 1: 在搜索框中输入测试 Payload

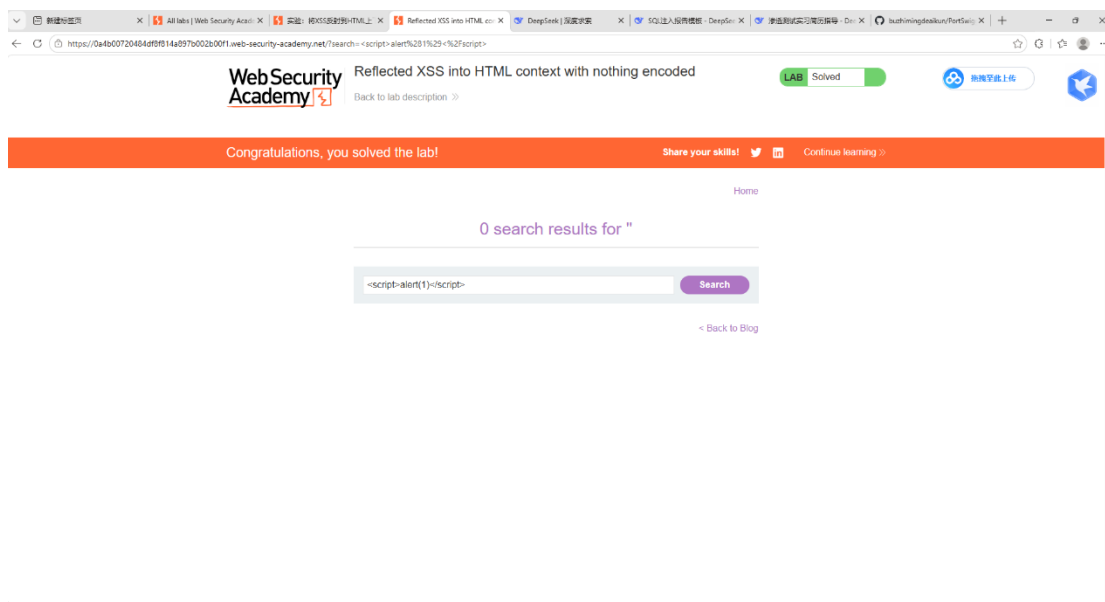


说明：在搜索框输入恶意 JavaScript 代码，准备提交。

第三步：触发并验证漏洞

点击“Search”按钮，浏览器执行了该请求，页面刷新。

图 2：成功触发弹窗并解决实验



说明：页面加载后，浏览器弹出了 1 的提示框。这意味着我们注入的 `<script>alert(1)</script>` 标签没有被浏览器当作纯文本，而是被当成了有效的 HTML 代码执行了。反射型 XSS 漏洞验证成功。

6. 漏洞原理

反射型 XSS 的本质是“输入即输出”，且输出未经过滤。

1. 用户通过 URL 或表单将恶意 Payload 发送给服务器。
2. 服务器没有对 Payload 进行任何编码转义（如将 `<` 转成 `<`），直接将其拼接

到返回给用户的 HTML 响应中。

3. 受害者的浏览器在解析 HTML 时，识别到了 `<script>` 标签，并将其当作本地 JavaScript 代码执行。

7. 漏洞影响

- **会话劫持**：攻击者可以构造恶意链接，诱骗受害者点击，从而窃取受害者浏览器中的 Cookie，直接登录受害者的账号。
- **钓鱼攻击**：伪造登录页面诱导受害者输入密码。
- **网页篡改**：在受害者看到的网页上显示虚假信息或恶意广告。

8. 修复建议

① **对输出内容进行 HTML 编码 (Context-Aware Output Encoding)**：在将搜索词输出到 HTML 页面时，后端必须对特殊字符进行转义。例如：

- 将 `<` 转义为 `<`;
- 将 `>` 转义为 `>`;
- 将 `"` 转义为 `"`;

② **内容安全策略 (CSP)**：配置 HTTP 响应头 `Content-Security-Policy: script-src 'self'`，禁止执行外部的不可信脚本，即使注入成功也无法执行恶意代码。

9. 工具

- **Google Chrome / Firefox**（浏览器开发者工具）
- **PortSwigger Web Security Academy**（靶场平台）